3.6.2 Token-based

Token-based authentication is a special case of identifier-only authentication that I distinguish primarily by whether the token (which is also acting as the identifier) is issued only after an initial authentication using some stronger authentication method. If you look at figure 3.6 and compare it to figure 3.5, you'll see that the flow now includes an initial registration step to enroll Alice and an authentication step to authenticate her for a given session.

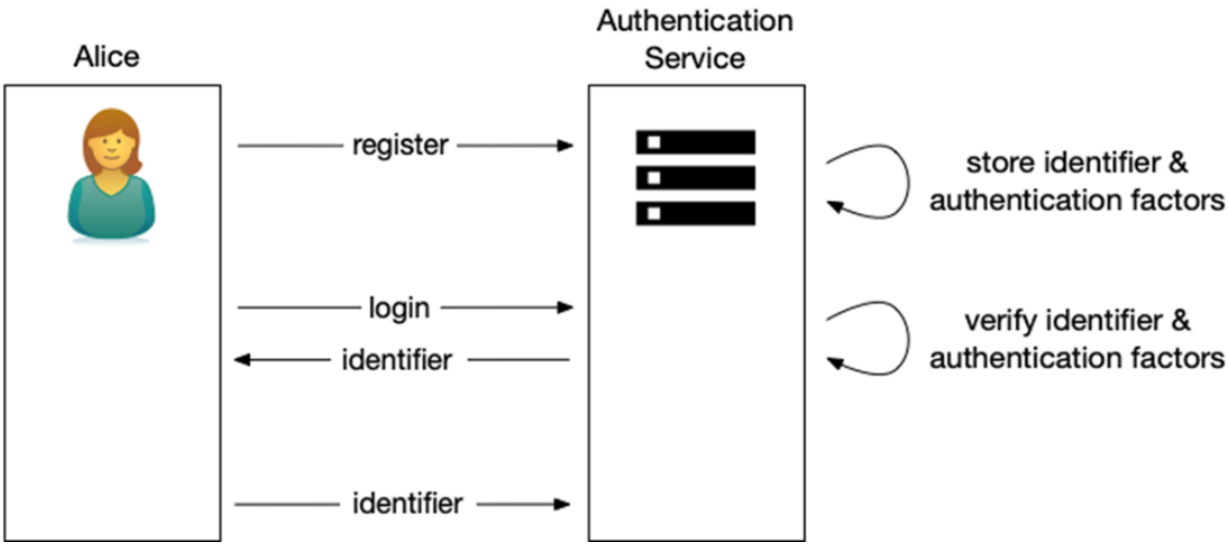


Figure 3.6 Token-based authentication flow. Alice begins by registering with the authentication service, which stores her identifier along with one or more authentication factors. During login, she presents her identifier and authentication factors. If verified, the service issues a cryptographically verifiable token that represents her authenticated session. For subsequent requests, Alice presents only the token (identifier), which the service uses to link the request to her previously authenticated session. This method enhances usability by eliminating the need to reenter credentials, but it depends on the token being securely stored and transmitted to prevent hijacking.

Compared with identifier-only authentication, token-based authentication offers more security by enrolling the requester, subject to any level of identity proofing, and then authenticating them before issuing the token.

Given the definition of token-based authentication, you might realize that websites can use cookies to implement tokens for session management. Even so, many cookies, most related to surveillance-based web advertising, are not authenticated. For example, in a scan I did of `www.allrecipes.com`